Partie 2 — Travaux pratiques

Réseau sécurisé pas à pas : DMZ, VLAN, pare-feu. Tutoriel sur Proxmox VE, pfSense et Kali Linux — environ 20 h. Chaque étape indique sur quelle machine travailler, quoi taper et ce que vous devez voir.

Avant de commencer

Ce cahier prolonge le cours « Architecture sécurisée ». Vous allez construire, configurer, attaquer puis durcir une architecture complète : double pare-feu, DMZ, VLAN, reverse-proxy, serveurs internes et supervision. Tout fonctionne sur un seul hôte Proxmox VE ; Kali Linux joue l'attaquant (depuis « Internet » ou depuis un poste interne compromis) et sert à vérifier que les règles font bien ce qu'on attend d'elles.

> **Principe pédagogique**
> On ne se contente pas de configurer : chaque règle est prouvée par un test. Un flux autorisé doit fonctionner, un flux interdit doit échouer, et le blocage doit apparaître dans les journaux.

> **Règle absolue — cadre légal**
> Les outils de Kali Linux ne s'utilisent que sur le laboratoire de la classe, sur les adresses indiquées dans ce cahier. Scanner ou attaquer un système sans autorisation écrite est un délit (accès frauduleux, articles 323-1 et suivants du Code pénal). Ne jamais lancer un scan vers le réseau de l'établissement ou vers Internet. Vérifiez toujours l'adresse cible avant d'appuyer sur Entrée.

Objectifs

- déployer un laboratoire virtualisé (bridges Linux, VLAN 802.1Q, machines clonées depuis des gabarits) ;
- installer et configurer deux pare-feu (pfSense ou OPNsense), des zones de confiance et une politique deny all ;
- publier un service via un reverse-proxy en DMZ (NAT, redirection de ports, TLS) ;
- segmenter le réseau interne en VLAN et filtrer les flux inter-VLAN selon le moindre privilège ;
- auditer l'architecture avec nmap et Kali Linux, comparer réseau plat et réseau segmenté ;
- durcir les serveurs (SSH, pare-feu local, services inutiles), centraliser les journaux ;
- produire des livrables professionnels : schéma annoté, matrice de flux, fiche de recette, rapport d'audit.

Organisation et durée

TP	Titre	Durée	Notion du cours
TP0	Préparer la plateforme Proxmox	1 h 30	Équipements, virtualisation
TP1	Réseau plat : mesurer le risque	1 h 30	Architecture plate, propagation latérale
TP2	Installer les pare-feu et les zones	2 h	Pare-feu, zones de confiance
TP3	VLAN et réseau interne	2 h	VLAN, segmentation, deny all
TP4	DMZ, reverse-proxy et NAT	2 h	DMZ, services exposés
TP5	Matrice de flux et règles de filtrage	2 h	Moindre privilège, sens des flux
TP6	Audit avec Kali et fiche de recette	2 h	Tests, preuves, journaux
TP7	Durcissement et journalisation	2 h	Défense en profondeur
TP8	Projet final et livrable	2 h + travail perso	Schéma annoté + justification

Parcours minimal (≈ 10 h) : TP0, TP2, TP3, TP4, TP5, TP6. Les TP1, TP7 et TP8 complètent la démarche (comparaison, durcissement, livrable noté).

Matériel nécessaire

	Configuration minimale	Configuration confortable
Hôte Proxmox	8 cœurs, 16 Go de RAM, 200 Go de disque	12 cœurs, 32 Go de RAM, 500 Go de SSD
Kali Linux	Une seule VM qu'on déplace de réseau en réseau	Deux VM : KALI-EXT et KALI-INT
Poste élève	Un navigateur web (interface Proxmox sur le port 8006) + client SSH	
Pas de serveur ?	Proxmox s'installe dans une VM sur votre PC (virtualisation imbriquée, 16 Go de RAM) : voir l'option « laboratoire sur son PC » ci-dessous.	

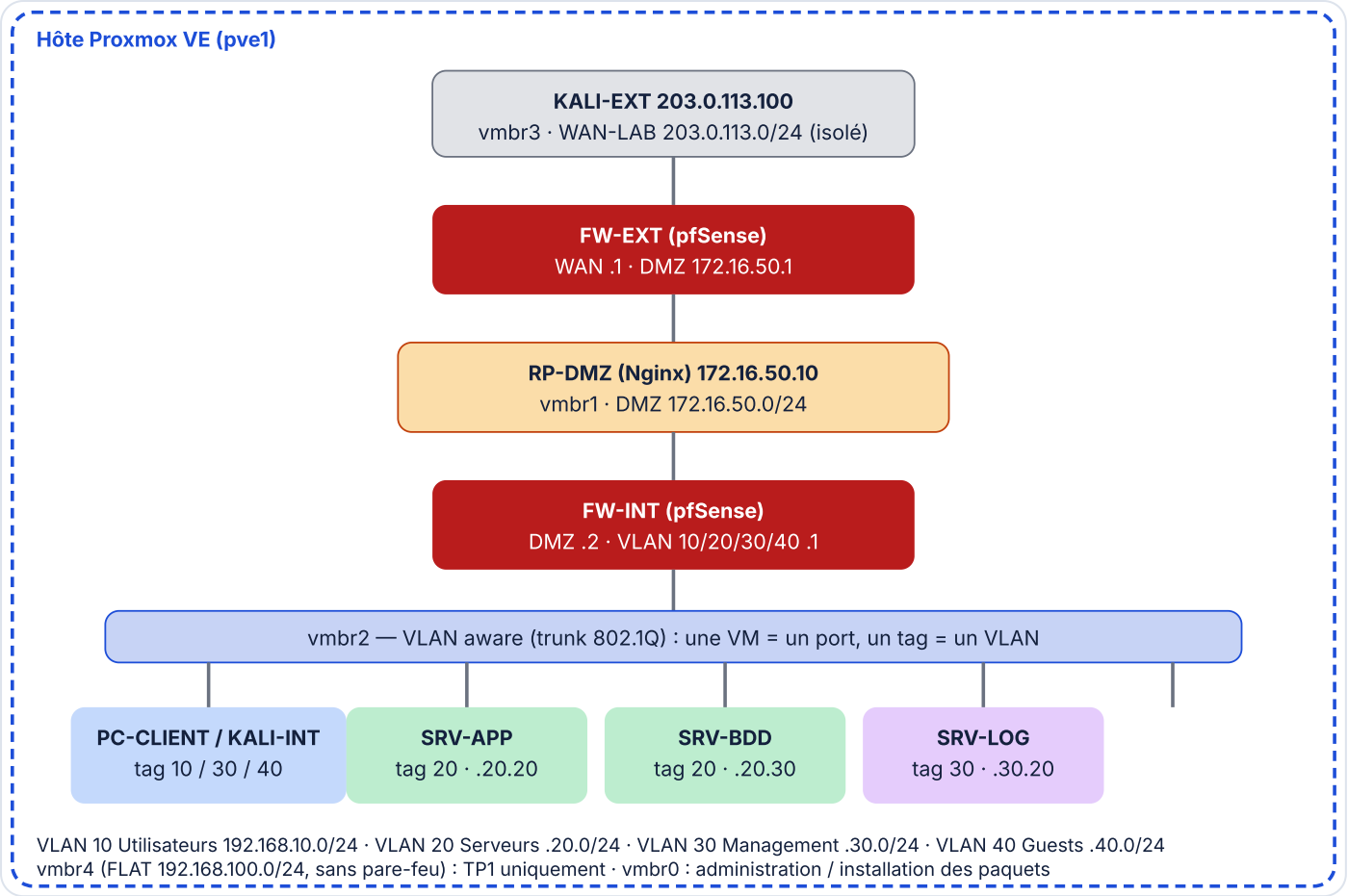
Comment lire ce cahier

Élément	Signification
SUR : MACHINE	La machine sur laquelle travailler. Couleur : rouge pare-feu, orange DMZ, vert serveurs, gris Kali, bleu Proxmox.
Bloc noir	Ce que vous voyez dans un terminal. Seul le texte blanc après l'invite est à taper ; vert = réponse attendue, rouge = erreur ou flux bloqué, jaune = avertissement, gris = commentaire. Le bouton « Copier » ne copie que les commandes.
Encadré vert / orange	« Résultat attendu » à comparer avec votre écran / « Si cela ne fonctionne pas » : pannes fréquentes et remèdes.
Cadres de réponse	Ils préparent le rapport final. Ce que vous écrivez est enregistré automatiquement dans votre navigateur.
Validation de fin de TP	À cocher avant de passer au suivant ; prenez un snapshot Proxmox.

Les adresses et noms d'interface peuvent différer

Les consoles montrent des exemples (interface `ens18`, adresse NAT de votre hyperviseur, numéros de version). Adaptez ce qui est propre à votre machine ; les adresses du laboratoire (203.0.113.x, 172.16.50.x, 192.168.x.x) restent identiques.

Architecture cible



Plan d'adressage et d'identification

VM (VMID)	Rôle	Bridge / tag	Adresse IP
FW-EXT (100)	Pare-feu externe pfSense	vmbr3 (WAN) + vmbr1 (DMZ)	WAN 203.0.113.1/24 ; DMZ 172.16.50.1/24
FW-INT (101)	Pare-feu interne pfSense	vmbr1 (côté DMZ) + vmbr2 (trunk, sans tag)	172.16.50.2/24 ; .1 dans chaque VLAN
RP-DMZ (110)	Reverse-proxy Nginx	vmbr1	172.16.50.10/24
SRV-APP (120)	Application web interne (port 8080)	vmbr2, tag 20	192.168.20.20/24
SRV-BDD (121)	Base de données MariaDB	vmbr2, tag 20	192.168.20.30/24

SRV-LOG (122)	Collecteur syslog	vmbr2, tag 30	192.168.30.20/24
PC-CLIENT (130)	Poste Debian XFCE (change de VLAN selon le test)	vmbr2, tag 10 / 30 / 40	DHCP (VLAN 10 et 40), 192.168.30.10 (VLAN 30)
KALI-EXT (140)	Attaquant sur « Internet »	vmbr3	203.0.113.100/24
KALI-INT (141)	Poste interne compromis / audit	vmbr2, tag 10 ou 40	DHCP

Gabarits : VM 900 (`tpl-debian`) et VM 901 (`tpl-kali`). **Convention** : un snapshot à la fin de chaque TP (`tp2-ok` , `tp3-ok` ...) pour revenir en arrière en cas d'erreur.

{{DONE:tp-intro}}

Option : le laboratoire sur son propre PC

Proxmox VE est installé dans une machine virtuelle appelée **pve1**, et toutes les machines du TP tournent à l'intérieur (virtualisation imbriquée). Machines environ 30 à 50 % plus lentes qu'avec Proxmox sur un serveur : démarrez-les progressivement. Un PC à processeur Apple (M1 et suivants) ne convient pas (Proxmox et Kali du TP sont en x86). La virtualisation (Intel VT-x ou AMD-V) doit être activée dans le BIOS/UEFI.

Ressource	Minimum	Confortable
Processeur	4 cœurs / 8 threads avec VT-x ou AMD-V	6 cœurs ou plus
Mémoire vive	16 Go (dont 10 Go pour pve1)	32 Go (dont 14 Go pour pve1)
Disque	120 Go libres, SSD fortement conseillé	200 Go sur SSD

Hyperviseur	Quand le choisir	Fiabilité de l'imbrication
VMware Workstation	Windows ou Linux ; le plus simple	Très bonne
Hyper-V	Windows 10/11 Pro, Éducation ou Entreprise	Très bonne

Linux / KVM (virt-manager)	Poste sous Linux	Excellente
VirtualBox	Si aucun autre choix	Variable : à tester (étape V)

> **Windows : conflits possibles**
> Hyper-V, WSL2, Docker Desktop ou l'« intégrité de la mémoire » peuvent empêcher VMware Workstation ou VirtualBox d'exposer la virtualisation à la VM. Si le test de l'étape V échoue, désactivez ces fonctions (puis redémarrez) ou utilisez Hyper-V.

Créer la VM pve1 selon votre hyperviseur

▼ **Guide A — VMware Workstation**

1. File > New Virtual Machine, **Custom (advanced)** ; « I will install the operating system later » ; Linux, Debian 12.x 64-bit ; nom `pve1`.
2. 1 processeur, **4 cœurs** ; mémoire **10240 Mo** (profil léger) ou 14336 Mo ; réseau **NAT** ; disque 100 Go, sans « Allocate all disk space now ».
3. Customize Hardware… > Processors : cocher **Virtualize Intel VT-x/EPT or AMD-V/RVI** (indispensable). New CD/DVD : l'ISO de Proxmox VE.
4. Edit > Virtual Network Editor > VMnet8 > NAT Settings : notez le sous-réseau et la passerelle (exemple : 192.168.199.0/24, passerelle 192.168.199.2).

▼ **Guide B — VirtualBox**

1. Nouvelle : nom `pve1`, ISO Proxmox, Linux / Debian 64-bit ; cochez **Skip Unattended Installation** ; 10240 Mo, 4 processeurs, disque 100 Go.
2. Configuration > Système > Processeur : **Enable Nested VT-x/AMD-V**. Si la case est grisée :

```
PS C:\Program Files\Oracle\VirtualBox> .\VBoxManage.exe modifyvm "pve1" --
nested-hw-virt on
$ .\VBoxManage.exe showvminfo "pve1" | Select-String "Nested"
Nested VT-x/AMD-V: enabled
```

3. Réseau : NAT, redirections de ports : `pve-web` TCP 127.0.0.1:8006 → 10.0.2.15:8006 ; `pve-ssh` TCP 127.0.0.1:2222 → 10.0.2.15:22.

▼ Guide C — Hyper-V (Windows Pro, Éducation, Entreprise)

```
# PowerShell en administrateur — activer Hyper-V puis redémarrer
$ Enable-WindowsOptionalFeature -Online -FeatureName Microsoft-Hyper-V -All
# Réseau NAT fixe pour le laboratoire
$ New-VMSwitch -SwitchName "LAB-NAT" -SwitchType Internal
$ New-NetIPAddress -IPAddress 192.168.77.1 -PrefixLength 24 -InterfaceAlias
"vEthernet (LAB-NAT)"
$ New-NetNat -Name LABNAT -InternalIPInterfaceAddressPrefix 192.168.77.0/24
# Après création de la VM pve1 (Génération 2, 10240 Mo sans mémoire dynamique,
disque 100 Go, ISO Proxmox)
$ Set-VMProcessor -VMName pve1 -Count 4 -ExposeVirtualizationExtensions $true
$ Set-VMNetworkAdapter -VMName pve1 -MacAddressSpoofing On
$ Set-VMFirmware -VMName pve1 -EnableSecureBoot Off
```

▼ Guide D — Linux / KVM

```
$ cat /sys/module/kvm_intel/parameters/nested
Y
$ sudo apt install -y qemu-kvm libvirt-daemon-system virtinst virt-manager
$ sudo usermod -aG libvirt,kvm $USER
$ sudo virt-install --name pve1 --memory 10240 --vcpus 4 --cpu host-
passthrough \
>  --disk size=100,format=qcow2,bus=virtio --cdrom ~/iso/proxmox-ve.iso \
>  --os-variant debian12 --network network=default,model=virtio --graphics
spice
```

Processeur AMD : remplacez `kvm_intel` par `kvm_amd` (la valeur peut être 1).

Étape P — Installer Proxmox VE dans pve1

SUR : PROXMOX — fenêtre de la VM pve1 (installateur graphique)

1. Menu de démarrage : **Install Proxmox VE (Graphical)** ; accepter l'EULA.
2. Target Harddisk : le disque de 100 Go, système de fichiers **ext4**.
3. Pays France, fuseau Europe/Paris, clavier French. Mot de passe root (à noter), e-mail `admin@lab.local`.
4. Management Network : hostname `pve1.lab.local` ; IP, passerelle et DNS selon le tableau.
5. Install ; à la fin, éjecter l'ISO et laisser redémarrer.

Hyperviseur	IP (CIDR)	Passerelle	DNS	Interface web

VMware (exemple)	192.168.199.100/24	192.168.199.2	192.168.199.2	https://192.168.199.100:8006
VirtualBox	10.0.2.15/24	10.0.2.2	10.0.2.3	https://127.0.0.1:8006
Hyper-V (LAB-NAT)	192.168.77.10/24	192.168.77.1	1.1.1.1	https://192.168.77.10:8006
Linux / KVM	192.168.122.10/24	192.168.122.1	192.168.122.1	https://192.168.122.10:8006

Étape V — Vérifier que l'imbrication fonctionne

SUR : PROXMOX — console de pve1, connexion root

```
$ grep -c -E 'vmx|svm' /proc/cpuinfo
4
$ lscpu | grep -i virtualization
Virtualization: VT-x
$ ls -l /dev/kvm
crw-rw---- 1 root kvm 10, 232 Oct 20 10:12 /dev/kvm
```

Résultat attendu

Le premier nombre est supérieur à 0 et le fichier `/dev/kvm` existe.

Si cela ne fonctionne pas

Résultat 0 et pas de `/dev/kvm` : l'hyperviseur n'expose pas la virtualisation (reprenez l'étape d'activation ; désactivez Hyper-V / WSL2 / intégrité de la mémoire sous Windows avec VMware ou VirtualBox). Virtualisation absente : activez VT-x ou SVM Mode dans le BIOS. Rien ne marche avec VirtualBox : utilisez VMware, Hyper-V ou KVM.

Connectez-vous ensuite à l'interface web (navigateur du PC, adresse du tableau, avancé > continuer malgré le certificat auto-signé, utilisateur `root`, realm « Linux PAM »). Pour pouvoir faire `apt update` : Datacenter > pve1 > Updates > Repositories, désactivez `pve-enterprise` (et la ligne ceph enterprise), puis Add > **No-Subscription**.

Étape N — Créer le bridge d'installation vmbr9

SUR : PROXMOX — console de pve1

Sur un serveur, les machines préparées au TP0 utilisent `vmbr0` pour accéder à Internet. Sur PC, on crée à la place `vmbr9` qui partage la connexion de pve1. Partout où le cahier parle du « bridge

d'installation », utilisez **vmbr9** (PC) ou **vmbr0** (serveur).

```
$ nano /etc/network/interfaces
# ajoutez ce bloc en fin de fichier :
auto vmbr9
iface vmbr9 inet static
    address 10.99.99.1/24
    bridge-ports none
    bridge-stp off
    bridge-fd 0
    post-up   echo 1 > /proc/sys/net/ipv4/ip_forward
    post-up   iptables -t nat -A POSTROUTING -s 10.99.99.0/24 -o vmbr0 -j
MASQUERADE
    post-down iptables -t nat -D POSTROUTING -s 10.99.99.0/24 -o vmbr0 -j
MASQUERADE
#NAT-INSTALLATION
```

```
$ ifreload -a
$ ip -br a show vmbr9
vmbr9 UP 10.99.99.1/24
$ iptables -t nat -L POSTROUTING -n
MASQUERADE all -- 10.99.99.0/24 0.0.0.0/0
```

Une machine rattachée à vmbr9 reçoit une adresse fixe dans 10.99.99.0/24, passerelle 10.99.99.1, DNS 1.1.1.1. Une fois la préparation terminée, **détachez chaque machine de vmbr9** : le laboratoire doit être isolé pendant les tests et les scans.

Profil léger (PC de 16 Go)

Machine	Profil standard	Profil léger
VM Proxmox (pve1)	14 Go, 6 vCPU	10 Go, 4 vCPU
FW-EXT, FW-INT	2 Go chacun	1 Go chacun
RP-DMZ, SRV-APP, SRV-LOG	1 Go chacun	512 Mo chacun
SRV-BDD	1 Go	768 Mo
PC-CLIENT + KALI-EXT + KALI-INT	1 poste Debian + 2 Kali	Un seul Kali (3 Go, 2 vCPU) qui joue les trois rôles
Faux Internet (203.0.113.100)	Serveur web sur KALI-EXT	Conteneur WEB-EXT (128 Mo)

Profil léger : partout où le cahier parle de PC-CLIENT, KALI-INT ou KALI-EXT, utilisez la même VM KALI en modifiant son bridge et son VLAN Tag. Sur vmbr3 (rôle KALI-EXT), donnez-lui `203.0.113.101/24` (l'adresse .100 est réservée à WEB-EXT, créé au TP5).

- **Ordre de démarrage** : FW-EXT, FW-INT, serveurs, puis Kali ; n'allumez que ce dont le TP a besoin.
- **Deux niveaux de sauvegarde** : snapshots Proxmox de chaque VM et snapshot de pve1 dans l'hyperviseur avant les manipulations risquées.
- **Portabilité** : exportez pve1 (OVA ou copie du disque) pour reprendre sur un autre poste.
- **Ressources** : secteur branché, applications gourmandes fermées, mise en veille désactivée.

Si cela ne fonctionne pas
« KVM virtualisation unavailable » : imbrication non active (étape V). Tout est très lent : trop de VM allumées ou disque mécanique. Pas d'accès à https://adresse:8006 : VirtualBox, vérifier la redirection de port ; sinon `ip -br a` sur la console de pve1. Pas d'Internet sur vmbr9 : vérifier MASQUERADE, l'adresse 10.99.99.x, la passerelle et le DNS.

Validation de fin de TP

- [ ] La VM pve1 démarre et l'interface web de Proxmox s'ouvre depuis le navigateur du PC
- [ ] /dev/kvm est présent dans pve1
- [ ] Le bridge vmbr9 fonctionne (10.99.99.1/24)
- [ ] Le profil (standard ou léger) est choisi

{{DONE:tp-pc}}

TP0 — Préparer la plateforme Proxmox

Durée 1 h 30 à 2 h · **Objectif** disposer d'un hôte Proxmox avec cinq bridges, un gabarit Debian, un gabarit Kali et des serveurs prêts à l'emploi · **À rendre** captures (bridges, VM, gabarits) et réponses aux questions.

Rappel : le bridge d'installation
Pour installer des paquets, les machines ont besoin d'Internet temporairement : `vmbr0` (serveur) ou `vmbr9` (PC). Dans la suite : « bridge d'installation ».

0.1 Créer les bridges du laboratoire

SUR : PROXMOX — Datacenter > pve1 > System > Network

1. Create > Linux Bridge ; laissez *Bridge ports* vide.
2. Créez **vmbr1** (comment : DMZ), **vmbr3** (WAN-LAB), **vmbr4** (FLAT).
3. Créez **vmbr2** (TRUNK-INTERNE) en cochant en plus **VLAN aware** : c'est ce qui permet d'utiliser les VLAN.
4. Cliquez sur **Apply Configuration**.

Bridge	Rôle	Bridge ports	VLAN aware
vmbr0	Existant : administration	carte existante	non
vmbr1	DMZ	vide	non
vmbr2	Trunk interne (VLAN 10, 20, 30, 40)	vide	**oui**
vmbr3	WAN-LAB (« Internet » simulé)	vide	non
vmbr4	FLAT (réseau plat du TP1)	vide	non

```
$ ip -br link show type bridge
vmbr1 DOWN ea:5f:9d:12:c4:77 <NO-CARRIER,BROADCAST,MULTICAST,UP>
# DOWN / NO-CARRIER est normal : aucune machine n'est encore branchée
$ bridge vlan show dev vmbr2
vmbr2  1 PVID Egress Untagged
```

Résultat attendu

Cinq bridges listés ; vmbr2 apparaît avec « vlan-id 1 PVID » (signe qu'il est VLAN aware).

Si cela ne fonctionne pas

« Apply Configuration » grisé : F5. vmbr2 absent de `bridge vlan show` : « VLAN aware » non coché, éditez vmbr2 puis Apply.

0.2 Téléverser les ISO

Datacenter > pve1 > local > ISO Images > Upload (ou Download from URL) : Debian 12 (netinst), pfSense CE (ou OPNsense) et Kali Linux (installateur).

0.3 Créer la VM du gabarit Debian (VM 900)

SUR : PROXMOX — bouton « Create VM »

Onglet	Champs
General	Node pve1 ; VM ID **900** ; Name **tpl-debian**

OS	ISO debian-12 netinst ; Type Linux
System	Valeurs par défaut ; cocher « Qemu Agent »
Disks	VirtIO Block ou SCSI ; 8 GiB
CPU / Memory	1 socket, 1 cœur ; 1024 MiB
Network	Bridge d'installation ; Model VirtIO ; Firewall décoché

Finish, Start, ouvrez la Console (noVNC).

0.4 Installer Debian dans le gabarit

Écran	Choix
Install	Install (mode texte)
Langue, pays, clavier	French, France, Français (AZERTY)
Hostname / Domain	tpl-debian / lab.local
Réseau	vmbr0 : automatique. vmbr9 : manuel, IP 10.99.99.50, masque 255.255.255.0, passerelle 10.99.99.1, DNS 1.1.1.1
Comptes	root (mot de passe à noter) ; utilisateur **etudiant**
Partitionnement	Guided - use entire disk ; All files in one partition
Logiciels	Décocher « Debian desktop environment » et « GNOME » ; cocher « SSH server » et « standard system utilities »
GRUB	Yes ; choisir le disque

0.5 Installer les outils communs et nettoyer le gabarit

SUR : TPL-DEBIAN — connecté en « etudiant »

```
$ sudo apt update && sudo apt full-upgrade -y
$ sudo apt install -y qemu-guest-agent openssh-server curl nmap netcat-openbsd
tcpdump ufw rsyslog dnsutils traceroute nginx
$ sudo systemctl enable qemu-guest-agent
$ sudo truncate -s 0 /etc/machine-id
```

```
$ sudo rm -f /etc/ssh/ssh_host_*
$ sudo poweroff
```

> **Pourquoi truncate et rm ?**
> Chaque clone doit avoir son propre identifiant machine et ses propres clés SSH ; sinon deux machines partageraient la même identité (problèmes de DHCP, clés SSH identiques).

0.6 Convertir en gabarit puis cloner

1. Clic droit sur la VM 900 > **Convert to template**.
2. Clic droit sur le gabarit > **Clone** : VM ID 120, Name srv-app, **Mode Full Clone**.
3. Recommencez pour SRV-BDD (121), SRV-LOG (122), RP-DMZ (110) et PC-CLIENT (130).

Au premier démarrage de chaque clone, régénérez les clés SSH et donnez-lui son nom :

```
$ sudo dpkg-reconfigure openssh-server
$ sudo hostnamectl set-hostname srv-app
$ hostnamectl | head -n 3
 Static hostname: srv-app
```

> **Si cela ne fonctionne pas**
> Même MAC/IP qu'un autre clone : vérifier « Full Clone » et que machine-id a été vidé. Pas d'Internet : vérifier le bridge d'installation, l'adresse (10.99.99.x sur vmbr9), la passerelle et le DNS.

0.7 Préparer Kali Linux et le poste client

VM	Paramètres
KALI (VM 901, gabarit)	ID 901 ; Name tpl-kali ; ISO Kali installer ; 2 cœurs ; 3072 MiB ; 30 GiB ; bridge d'installation, VirtIO. Installation par défaut avec bureau Xfce, utilisateur **etudiant**, puis conversion en gabarit.
PC-CLIENT (VM 130)	Clone de tpl-debian ; 1536 MiB (profil standard). Profil léger : on utilise Kali à la place.

```
# PC-CLIENT, profil standard uniquement
$ sudo apt install -y task-xfce-desktop firefox-esr
```

0.8 Préparer les serveurs (avec Internet temporaire)

SUR : SRV-APP — application web interne sur le port 8080

```
$ sudo mkdir -p /var/www/app
$ echo '<h1>Application interne - SRV-APP</h1>' | sudo tee
/var/www/app/index.html
$ printf 'server {\n listen 8080;\n root /var/www/app;\n index index.html;\n}\n'
| sudo tee /etc/nginx/conf.d/app.conf
$ sudo nginx -t && sudo systemctl reload nginx
$ curl -I http://localhost:8080
HTTP/1.1 200 OK
```

SUR : SRV-BDD — MariaDB, volontairement permissive pour le TP1, durcie au TP7

```
$ sudo apt install -y mariadb-server
$ sudo sed -i 's/^bind-address.*/bind-address = 0.0.0.0/'
/etc/mysql/mariadb.conf.d/50-server.cnf
$ sudo systemctl restart mariadb
$ sudo mysql -e "CREATE DATABASE clients; USE clients; CREATE TABLE contacts(id
INT, nom VARCHAR(50)); INSERT INTO contacts VALUES (1,'Alice Martin'),(2,'Karim
Benali'); CREATE USER 'app'@'%' IDENTIFIED BY 'Lab_Passw0rd'; GRANT ALL ON
clients.* TO 'app'@'%'; FLUSH PRIVILEGES;"
$ sudo mysql -e "SELECT * FROM clients.contacts;"
1 | Alice Martin    2 | Karim Benali
```

Résultat attendu

SRV-APP répond « 200 OK » sur 8080 et SRV-BDD affiche la table contacts. Éteignez chaque machine et **supprimez sa carte du bridge d'installation** : elle n'aura plus Internet.

Question 0.1. Quelle différence y a-t-il entre un bridge « VLAN aware » et un bridge classique ? Que se passe-t-il quand on renseigne un « VLAN Tag » sur la carte réseau d'une VM ?

Votre réponse (enregistrée automatiquement)…

Question 0.2. Pourquoi crée-t-on des gabarits puis des clones plutôt que d'installer chaque machine séparément ? Citez un avantage de sécurité.

Votre réponse (enregistrée automatiquement)…

Question 0.3. Pourquoi installe-t-on tous les paquets avant de rattacher les machines aux bridges isolés ?

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] Les bridges vmbr1 à vmbr4 existent, vmbr2 est « VLAN aware » (capture de bridge vlan show)
- [ ] Les gabarits tpl-debian (900) et tpl-kali (901) sont convertis ; les clones démarrent avec des noms d'hôte distincts
- [ ] SRV-APP répond sur le port 8080 ; SRV-BDD contient la base clients
- [ ] Les machines sont détachées du bridge d'installation. Snapshot « tp0-ok » pris sur chaque VM

TP1 — Réseau plat : mesurer le risque

Durée 1 h 30 · **Objectif** constater ce qu'un poste compromis peut atteindre dans une architecture plate, sans aucun pare-feu · **Prérequis** TP0 · **À rendre** tableau des ressources atteintes, captures, réponses, snapshot « tp1-plat ».

1.1 Brancher les machines sur le réseau plat (vmbr4)

SUR : PROXMOX — pour chaque VM : Hardware > Network Device > Edit

Pour SRV-APP, SRV-BDD, PC-CLIENT (ou KALI) : **Bridge = vmbr4**, VLAN Tag vide, Firewall décoché. OK, puis démarrez les machines.

1.2 Donner une adresse fixe à chaque machine

SUR : SRV-APP — console Proxmox de la VM

```
$ ip -br a
$ sudo ip link set ens18 up
$ sudo ip addr add 192.168.100.20/24 dev ens18
$ ip -br a
ens18 UP 192.168.100.20/24
```

Machine	Adresse	Interface (à vérifier)
SRV-APP	192.168.100.20/24	ens18
SRV-BDD	192.168.100.30/24	ens18
PC-CLIENT	192.168.100.50/24	ens18
KALI	192.168.100.66/24	eth0 (ou ens18)

SUR : KALI — vérification

```
$ ping -c 3 192.168.100.20
3 packets transmitted, 3 received, 0% packet loss
```

> **Si le ping ne répond pas**
> Vérifiez que les deux machines sont sur vmbr4 sans VLAN Tag, que l'interface est UP et que les adresses sont dans le même /24.

1.3 Jouer le scénario : KALI est un poste compromis

SUR : KALI — terminal — rôle : poste d'employé compromis

L'attaquant n'a aucun droit particulier : il est simplement présent sur le réseau.

```
$ nmap -sn 192.168.100.0/24
192.168.100.20, .30, .50 : Host is up
$ nmap -sV -p- --min-rate 1000 192.168.100.20 192.168.100.30
.20 → 22/ssh, 80/http, 8080/http   ·   .30 → 22/ssh, 3306/mysql
$ mysql -h 192.168.100.30 -u app -p -e "SELECT * FROM clients.contacts;"
1 | Alice Martin    2 | Karim Benali
$ nc -zv 192.168.100.30 22
Connection to 192.168.100.30 22 port [tcp/ssh] succeeded!
$ curl -s http://192.168.100.20:8080
<h1>Application interne - SRV-APP</h1>
```

Client mysql absent sur Kali : installez-le temporairement, ou remplacez par `nc -zv 192.168.100.30 3306` : « succeeded » prouve déjà que la base est joignable.

Complétez le tableau des ressources atteintes depuis le poste compromis :

Machine	Port	Service	Atteignable ? (O/N)	Sensible ? Pourquoi ?

Question 1.1. Combien de services différents un attaquant déjà présent dans le réseau a-t-il pu atteindre ? Lesquels n'ont aucune raison d'être accessibles depuis un poste utilisateur ?

Votre réponse (enregistrée automatiquement)...

Question 1.2. Quels critères DICT sont menacés par l'accès à la base de données ? Justifiez en une phrase pour chacun.

Votre réponse (enregistrée automatiquement)...

Question 1.3. Expliquez avec vos mots la notion de propagation latérale à partir de ce que vous venez d'observer.

Votre réponse (enregistrée automatiquement)...

Question 1.4. Proposez trois mesures du cours qui auraient limité cette exposition.

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] Le tableau est rempli, avec une capture du scan nmap de l'étape 1.3
- [ ] Vous avez lu le contenu de la table contacts depuis KALI (preuve)
- [ ] Snapshot « tp1-plat » pris. Les machines sont ensuite retirées de vmbr4

TP2 — Installer les pare-feu et définir les zones

Durée 2 h à 2 h 30 · **Objectif** installer FW-EXT et FW-INT (pfSense), nommer les zones, supprimer les règles permissives et relier les deux pare-feu · **Prérequis** TP0, ISO pfSense CE (OPNsense : mêmes principes, menus un peu différents) · **À rendre** tableau des zones, captures, réponses.

Architecture : Internet – FW-EXT – DMZ – FW-INT – réseau interne. Vous installez d'abord FW-EXT (côté Internet), puis FW-INT.

2.1 Créer la VM FW-EXT (VM 100)

SUR : PROXMOX — Create VM

Onglet	Champs
General	VM ID 100 ; Name fw-ext
OS	ISO pfSense CE ; Type Other
System / Disks	Défaut ; disque 16 GiB
CPU / Memory	1 core ; 2048 MiB (léger : 1024)
Network	net0 : Bridge **vmbr3** (WAN), VirtIO, Firewall décoché

Après Finish : VM 100 > Hardware > Add > Network Device : **net1 sur vmbr1** (DMZ), VirtIO, Firewall décoché. Dans pfSense, net0 sera `vtnet0` et net1 `vtnet1`.

2.2 Installer pfSense

SUR : FW-EXT — console Proxmox de la VM 100

Accept ; Install pfSense > OK ; keymap par défaut ; partitionnement **Auto (UFS)** ; Entire Disk > Finish > Commit ; Manual Configuration : No ; Reboot, puis retirez l'ISO (Hardware > CD/DVD Drive > Do not use any media).

2.3 Attribuer les interfaces et les adresses (console)

WAN = vtnet0 (vmbr3), LAN = vtnet1 (vmbr1, renommé DMZ plus tard).

```
Do you want to set up VLANs now [y|n]? n
Enter the WAN interface name: vtnet0
Enter the LAN interface name: vtnet1
Enter the Optional 1 interface name: (rien)
Do you want to proceed [y|n]? y
```

Menu principal, option **2** (Set interface(s) IP address) :

```
Enter an option: 2
Enter the number of the interface you wish to configure: 1
Configure IPv4 address WAN interface via DHCP? n
Enter the new WAN IPv4 address: 203.0.113.1
Enter the new WAN IPv4 subnet bit count: 24
# passerelle : aucune (Entrée) ; IPv6 : non ; HTTP : non
Enter the number of the interface you wish to configure: 2
Enter the new LAN IPv4 address: 172.16.50.1
Enter the new LAN IPv4 subnet bit count: 24
Do you want to enable the DHCP server on LAN? n
You can now access the webConfigurator at https://172.16.50.1/
```

> **Les questions peuvent différer**
> Selon la version de pfSense, l'ordre ou le libellé varie. Retenez l'essentiel : WAN en 203.0.113.1/24 sans passerelle, LAN en 172.16.50.1/24, pas de serveur DHCP.

2.4 Se connecter à l'interface web de FW-EXT

SUR : KALI — poste d'administration placé temporairement sur vmbr1 (DMZ)

```
# Dans Proxmox : carte réseau de KALI sur vmbr1, sans VLAN Tag
$ sudo ip addr add 172.16.50.99/24 dev eth0
$ ping -c 2 172.16.50.1
64 bytes from 172.16.50.1: icmp_seq=1 ttl=64
$ curl -k -I https://172.16.50.1 | head -n 1
HTTP/1.1 200 OK
```

Ouvrez Firefox sur `https://172.16.50.1`, acceptez le certificat, connectez-vous avec `admin` / `pfsense`. Dans l'assistant (Wizard) : hostname `fw-ext`, domaine `lab.local`, DNS 1.1.1.1. À « Configure WAN Interface » : type Static, IP 203.0.113.1, masque 24, et **décochez « Block RFC1918 Private Networks » et « Block bogon networks »** (les adresses de laboratoire seraient rejetées). LAN inchangé ; choisissez un **nouveau mot de passe fort** ; Reload, Finish.

2.5 Nommer la zone DMZ et supprimer les règles permissives

SUR : FW-EXT — https://172.16.50.1

1. Interfaces > LAN : Description **DMZ** ; Save, Apply Changes.
2. Firewall > Rules > DMZ : supprimez les deux règles « Default allow LAN to any rule » (IPv4 et IPv6). **Conservez l'anti-lockout.**

Résultat attendu

L'onglet DMZ ne contient plus que « Anti-Lockout Rule » ; l'onglet WAN n'a aucune règle : tout trafic entrant est bloqué par défaut.

Si vous perdez l'accès à l'interface web

Console pfSense, option 8 (Shell) : `pfctl -d` désactive temporairement le filtrage ; corrigez, puis `pfctl -e`.

2.6 Créer la VM FW-INT (VM 101) et l'installer

SUR : PROXMOX — Create VM

Élément	Valeur
General	VM ID 101 ; Name fw-int ; ISO pfSense ; Type Other ; disque 16 GiB ; 1 core ; 2048 MiB (léger : 1024)
net0	Bridge **vmbr1** (côté DMZ), VirtIO, Firewall décoché
net1	Bridge **vmbr2**, **VLAN Tag vide** (la carte reçoit tous les VLAN : c'est un trunk), VirtIO, Firewall décoché

SUR : FW-INT — console, installation comme à l'étape 2.2

Répondez **oui** aux VLAN : vtnet1 sera le trunk et le VLAN 30 (Management) servira d'interface « LAN ».

```
Do you want to set up VLANs now [y|n]? y
Enter the parent interface name for the new VLAN: vtnet1
Enter the VLAN tag (1-4094): 30
WAN interface: vtnet0
LAN interface: vtnet1.30
# Option 2 :
WAN : 172.16.50.2 /24, passerelle amont 172.16.50.1
```

```
LAN : 192.168.30.1 /24, pas de DHCP
https://192.168.30.1/
```

2.7 Se connecter à FW-INT depuis le VLAN 30 et le configurer

SUR : KALI — carte sur vmbr2 avec VLAN Tag 30

```
$ sudo ip addr flush dev eth0
$ sudo ip addr add 192.168.30.10/24 dev eth0
$ sudo ip route add default via 192.168.30.1
$ ping -c 2 192.168.30.1
64 bytes from 192.168.30.1: icmp_seq=1 ttl=64
```

Ouvrez `https://192.168.30.1` (admin / pfsense), suivez l'assistant : hostname `fw-int`, domaine `lab.local`, nouveau mot de passe. À « Configure WAN Interface » : IP statique 172.16.50.2/24, passerelle 172.16.50.1, **décochez les deux blocages**. Puis :

a. **Renommer les interfaces** : WAN → `DMZ_LINK`, LAN → `MGMT`.
b. **Désactiver le NAT sortant** (Firewall > NAT > Outbound : « Disable Outbound NAT rule generation ») : entre la DMZ et le réseau interne on route, on ne fait pas de NAT.
c. **Désactiver reply-to** (System > Advanced > Firewall & NAT : « Disable reply-to on WAN rules ») : sinon les réponses au trafic entrant par DMZ_LINK repartiraient via FW-EXT et seraient bloquées.
d. **Supprimer la règle permissive** : Firewall > Rules > MGMT, supprimez « Default allow LAN to any rule » (IPv4 et IPv6), conservez l'anti-lockout. Apply Changes après chaque modification.

2.8 Relier les deux pare-feu : routes

SUR : FW-EXT — https://172.16.50.1 (depuis le poste en DMZ)

FW-INT connaît FW-EXT comme passerelle par défaut. FW-EXT doit apprendre où se trouve le réseau interne.

1. System > Routing > Gateways > Add : Interface DMZ, IPv4, Name `GW_INT`, Gateway `172.16.50.2`, cocher *Disable Gateway Monitoring*.
2. System > Routing > Static Routes > Add : destination `192.168.0.0/16`, gateway `GW_INT`. Apply Changes.

2.9 Tester la liaison entre les pare-feu

```
# FW-EXT, console, option 7 (Ping host)
Enter a host name or IP address: 172.16.50.2
3 packets transmitted, 3 packets received, 0.0% packet loss
```

Faites de même depuis FW-INT vers 172.16.50.1, puis depuis KALI (VLAN 30) vers 192.168.30.1. Classez enfin les zones :

Zone	Pare-feu / interface	Bridge ou VLAN	Niveau de confiance
Internet	FW-EXT / WAN	vmbr3	
DMZ			
Management			
Utilisateurs (TP3)			
Serveurs (TP3)			
Invités (TP3)			

Si cela ne fonctionne pas

Ping FW-INT → FW-EXT échoue : net0 de FW-INT sur vmbr1 ? adresses .1 et .2 en /24 ? « Block private networks » décoché sur DMZ_LINK ? Pas d'accès à https://192.168.30.1 : VLAN Tag 30 sur la carte de KALI, adresse 192.168.30.10/24, net1 de FW-INT sur vmbr2 sans tag.

Question 2.1. Pourquoi supprime-t-on la règle « allow LAN to any » installée par défaut ? Quel principe du cours cela illustre-t-il ?

Votre réponse (enregistrée automatiquement)...

Question 2.2. Pourquoi désactive-t-on le NAT sortant sur FW-INT ? Où le NAT est-il réalisé pour sortir vers « Internet » ?

Votre réponse (enregistrée automatiquement)...

Question 2.3. Quelle est l'utilité de la règle anti-verrouillage (anti-lockout) ? Quel risque y a-t-il à la retirer ?

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] Les deux pare-feu sont accessibles par leur interface web, mots de passe changés
- [ ] Les ping entre FW-EXT, FW-INT et KALI (VLAN 30) fonctionnent
- [ ] Aucune règle « allow any » ne subsiste ; route statique 192.168.0.0/16 en place ; reply-to désactivé sur FW-INT
- [ ] Tableau des zones complété ; snapshots « tp2-ok » pris sur FW-EXT et FW-INT

TP3 — VLAN et réseau interne

Durée 2 h · **Objectif** segmenter le réseau interne en quatre VLAN routés par FW-INT, avec DHCP, et constater l'effet de « tout est bloqué par défaut » · **Prérequis** TP2 · **À rendre** plan de VLAN, captures des interfaces et des journaux de blocage, réponses.

3.1 Créer les VLAN 10, 20 et 40 dans FW-INT

SUR : FW-INT — https://192.168.30.1 depuis KALI en VLAN 30

Interfaces > Assignments > VLANs > Add : Parent `vtnet1`, tag 10, description USERS. Recommencez avec le tag 20 (SERVERS) et le tag 40 (GUESTS). Le VLAN 30 existe déjà. **Attendu** : quatre lignes `vtnet1.10/.20/.30/.40`.

3.2 Assigner et configurer les interfaces VLAN

Interfaces > Assignments : ajoutez les VLAN 10, 20 et 40 (ils deviennent OPT1, OPT2, OPT3). Pour chacune : Enable, Description, IPv4 Static, adresse. Save, Apply Changes.

Interface	VLAN	Description	Adresse IPv4
OPT1	10	USERS	192.168.10.1/24
OPT2	20	SERVERS	192.168.20.1/24
LAN (existant)	30	MGMT	192.168.30.1/24

OPT3	40	GUESTS	192.168.40.1/24

3.3 Activer le DHCP sur USERS et GUESTS

Services > DHCP Server > USERS : Enable, plage `192.168.10.100` à `192.168.10.150`. Idem sur GUESTS (`192.168.40.100` à `.150`). Pas de DHCP sur SERVERS ni MGMT : les serveurs ont des adresses fixes.

3.4 Rattacher les machines aux VLAN (dans Proxmox)

SUR : PROXMOX — VM > Hardware > Network Device > Edit

Machine	Bridge	VLAN Tag	Adressage
SRV-APP	vmbr2	20	192.168.20.20/24 fixe
SRV-BDD	vmbr2	20	192.168.20.30/24 fixe
SRV-LOG	vmbr2	30	192.168.30.20/24 fixe
KALI / PC-CLIENT	vmbr2	10, 30 ou 40	DHCP

SUR : SRV-APP — adresse fixe permanente

```
$ sudo nano /etc/network/interfaces
# remplacez le bloc de ens18 par :
auto ens18
iface ens18 inet static
    address 192.168.20.20/24
    gateway 192.168.20.1
$ sudo systemctl restart networking
$ ip route
default via 192.168.20.1 dev ens18 onlink
```

Faites de même pour SRV-BDD (192.168.20.30, passerelle 192.168.20.1) et SRV-LOG (192.168.30.20, passerelle 192.168.30.1).

3.5 Créer les alias de FW-INT

Firewall > Aliases > Add, puis Apply Changes. Les alias rendent les règles lisibles et évitent les erreurs ; vous les réutiliserez aux TP4 et TP5.

Nom	Type	Contenu

RFC1918	Network(s)	10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16
RP_DMZ	Host(s)	172.16.50.10
SRV_APP	Host(s)	192.168.20.20
SRV_BDD	Host(s)	192.168.20.30
SRV_LOG	Host(s)	192.168.30.20
ADMIN_PC	Host(s)	192.168.30.10
ADMIN_PORTS	Port(s)	22, 443

3.6 Observer le comportement par défaut (deny all)

SUR : KALI — carte sur vmbr2, VLAN Tag 10 (poste utilisateur)

```
$ sudo dhclient -r eth0 ; sudo dhclient -v eth0
DHCPACK of 192.168.10.100 from 192.168.10.1
$ ping -c 3 192.168.10.1
3 packets transmitted, 0 received, 100% packet loss
$ curl -m 5 http://192.168.20.20:8080
curl: (28) Connection timed out after 5001 milliseconds
```

Le poste a bien une adresse (DHCP) mais ne peut rien joindre : aucune règle n'autorise ces flux. Observez le blocage :

SUR : FW-INT — Status > System Logs > Firewall Chaque ligne « Block » est un paquet bloqué par la règle implicite « Default deny rule ».

Question 3.1. Le ping vers la passerelle et le curl échouent alors que le poste a bien reçu une adresse. Pourquoi ? Pourquoi le DHCP fonctionne-t-il malgré tout ?

Votre réponse (enregistrée automatiquement)...

Question 3.2. Recopiez une ligne de blocage du journal et indiquez : interface, adresse source, adresse destination, port, action.

Votre réponse (enregistrée automatiquement)...

Question 3.3. Deux VM situées dans deux VLAN différents peuvent-elles se joindre sans passer par FW-INT ? Quelle est la conséquence pour la sécurité ?

Votre réponse (enregistrée automatiquement)...

Question 3.4. Un VLAN est-il à lui seul une protection ? Appuyez-vous sur ce que vous venez de constater.

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] Quatre interfaces VLAN (10, 20, 30, 40) actives sur FW-INT avec la bonne adresse
- [ ] KALI obtient une adresse DHCP dans le VLAN 10, puis dans le VLAN 40 après changement de tag
- [ ] Les serveurs ont leur adresse fixe permanente ; les alias sont créés
- [ ] Le journal montre vos essais bloqués. Snapshots « tp3-ok » pris

TP4 — DMZ, reverse-proxy et NAT

Durée 2 h · **Objectif** publier l'application interne sur « Internet » à travers un reverse-proxy en DMZ, sans jamais exposer le réseau interne · **Prérequis** TP3 · **À rendre** captures des règles NAT, des règles de FW-INT, des tests depuis KALI, réponses.

Chemin d'une requête : Internet (KALI) → FW-EXT (NAT) → RP-DMZ (Nginx) → FW-INT (règle DMZ_LINK) → SRV-APP.

4.1 Placer RP-DMZ en DMZ et lui donner son réseau

Proxmox : VM RP-DMZ (110), carte sur **vmbr1**, VLAN Tag vide.

SUR : RP-DMZ — console Proxmox

```
$ sudo nano /etc/network/interfaces
auto ens18
iface ens18 inet static
    address 172.16.50.10/24
    gateway 172.16.50.1
    up ip route add 192.168.0.0/16 via 172.16.50.2
$ sudo systemctl restart networking
$ ip route get 192.168.20.20
192.168.20.20 via 172.16.50.2 dev ens18 src 172.16.50.10
```

Piège classique : le routage asymétrique

Sans la ligne `up ip route add 192.168.0.0/16 via 172.16.50.2`, `ip route get` afficherait « via 172.16.50.1 » (FW-EXT). Les paquets sortiraient par FW-EXT et reviendraient par FW-INT : le pare-feu à états rejette ces réponses « inattendues ».

4.2 Certificat TLS et configuration du reverse-proxy

```
$ sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout
/etc/ssl/private/lab.key -out /etc/ssl/certs/lab.crt -subj '/CN=lab.local'
$ sudo rm -f /etc/nginx/sites-enabled/default
$ sudo nano /etc/nginx/conf.d/proxy.conf
```

Contenu de `/etc/nginx/conf.d/proxy.conf` (à recopier tel quel) :

```
server {
    listen 80;
    return 301 https://$host$request_uri;
}
server {
    listen 443 ssl;
    ssl_certificate     /etc/ssl/certs/lab.crt;
    ssl_certificate_key /etc/ssl/private/lab.key;
    ssl_protocols TLSv1.2 TLSv1.3;
    location / {
        proxy_pass http://192.168.20.20:8080;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
```

```
    }
}
```

```
$ sudo nginx -t && sudo systemctl reload nginx
nginx: configuration file /etc/nginx/nginx.conf test is successful
$ ss -tlnp | grep nginx
LISTEN 0.0.0.0:80 · 0.0.0.0:443
```

Si cela ne fonctionne pas

`nginx -t` signale une erreur : point-virgule manquant ou accolade non fermée (la ligne fautive est indiquée). « cannot load certificate » : vérifiez les chemins `/etc/ssl/certs/lab.crt` et `/etc/ssl/private/lab.key`.

4.3 Publier le service sur FW-EXT (redirection de ports NAT)

SUR : FW-EXT — Firewall > NAT > Port Forward > Add

Interface **WAN** ; protocole TCP ; destination *WAN address* ; port **HTTPS (443)** ; Redirect target IP **172.16.50.10** ; port HTTPS (443) ; *Filter rule association : Add associated filter rule*. Save, Apply. Recommencez avec le port HTTP (80). Vérifiez Firewall > Rules > WAN : seules ces deux règles (TCP 443 et 80 vers 172.16.50.10) autorisent du trafic entrant.

4.4 Autoriser le strict nécessaire vers l'interne (FW-INT)

SUR : FW-INT — Firewall > Rules > DMZ_LINK > Add

Action Pass ; TCP ; Source alias `RP_DMZ` ; Destination alias `SRV_APP` ; port **8080** ; *Log* coché ; description « RP-DMZ vers SRV-APP 8080 ». Ajoutez ensuite en dernier une règle **Block, any, any, Log coché**, puis Apply Changes.

Action	Proto	Source	Destination	Port	Log
Pass	TCP	RP_DMZ	SRV_APP	8080	oui
Block	any	any	any	any	oui

4.5 Tester depuis « Internet »

SUR : KALI — carte sur vmbr3 (WAN-LAB), sans VLAN Tag

```
$ sudo ip addr flush dev eth0
$ sudo ip addr add 203.0.113.101/24 dev eth0
```

```
$ sudo ip route add default via 203.0.113.1
$ curl -k -I https://203.0.113.1
HTTP/1.1 200 OK
$ curl -k https://203.0.113.1
<h1>Application interne - SRV-APP</h1>
$ curl -I http://203.0.113.1
HTTP/1.1 301 Moved Permanently   Location: https://203.0.113.1/
$ curl -m 5 http://192.168.20.20:8080
curl: (28) Connection timed out after 5001 milliseconds
```

Les trois premières commandes réussissent (l'application est publiée), la quatrième échoue : le réseau interne n'est pas joignable depuis Internet. Côté serveur : `sudo tail -n 2 /var/log/nginx/access.log` sur SRV-APP montre que les requêtes arrivent de `172.16.50.10`.

Si cela ne fonctionne pas

Timeout vers 203.0.113.1 : journaux de FW-EXT (une ligne « Block » sur WAN = règle NAT/WAN manquante) ; KALI sur vmbr3 avec route par défaut 203.0.113.1. « 502 Bad Gateway » : Nginx n'atteint pas SRV-APP (règle DMZ_LINK, route 192.168.0.0/16 de RP-DMZ, SRV-APP écoute sur 8080). Le blocage ne s'affiche pas : « Log packets » coché sur la règle de blocage ?

Question 4.1. Les trois premières commandes fonctionnent, la quatrième échoue. Expliquez pourquoi, en citant le rôle de la DMZ et du double pare-feu.

Votre réponse (enregistrée automatiquement)...

Question 4.2. Dans les journaux de SRV-APP, quelle est l'adresse source des requêtes ? Pourquoi n'est-ce pas celle de KALI, et quel en-tête permet de la retrouver ?

Votre réponse (enregistrée automatiquement)...

Question 4.3. Supposons que RP-DMZ soit compromis. Que peut atteindre l'attaquant dans le réseau interne avec les règles actuelles ? Que faudrait-il pour réduire encore ce risque ?

Votre réponse (enregistrée automatiquement)...

Question 4.4. Pourquoi redirige-t-on le port 80 vers le 443 plutôt que de supprimer le port 80 ?

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] Le site est accessible en HTTPS depuis KALI à 203.0.113.1 ; la requête directe vers 192.168.20.20 échoue
- [ ] Seules deux règles existent sur le WAN de FW-EXT (80 et 443 vers RP-DMZ)
- [ ] Sur FW-INT, DMZ_LINK n'autorise que RP_DMZ vers SRV_APP:8080 ; le reste est bloqué et journalisé
- [ ] Snapshots « tp4-ok » pris

TP5 — Matrice de flux et règles de filtrage

Durée 2 h · **Objectif** décider d'abord, configurer ensuite : traduire une matrice de flux en règles de pare-feu précises (moindre privilège) · **Prérequis** TP4 · **À rendre** matrice complétée, règles de FW-INT et FW-EXT en captures, tests de l'étape 5.6.

5.1 Compléter la matrice de flux (avant de configurer quoi que ce soit)

Pour chaque flux, décidez **A** (autorisé) ou **R** (refusé) et justifiez en une phrase. **Ne configurez rien avant d'avoir rempli la matrice.**

N°	Source	Destination	Service / port	A / R	Justification
1	Internet	RP-DMZ	TCP 80, 443	—	
2	Internet	Réseau interne	tous	—	
3	RP-DMZ	SRV-APP	TCP 8080	—	
4	RP-DMZ	SRV-BDD	TCP 3306	—	
5	DMZ	VLAN Utilisateurs	tous	—	

6	VLAN Utilisateurs	SRV-APP	TCP 8080	—	
7	VLAN Utilisateurs	SRV-BDD	TCP 3306	—	
8	VLAN Utilisateurs	Internet	TCP 80, 443	—	
9	VLAN Utilisateurs	VLAN Management	tous	—	
10	ADMIN_PC (Mgmt)	Serveurs et DMZ	TCP 22, 443	—	
11	VLAN Guests	Internet	TCP 80, 443	—	
12	VLAN Guests	Réseaux internes	tous	—	
13	VLAN Serveurs	Internet	tous	—	
14	VLAN Serveurs	SRV_LOG	UDP/TCP 514 (optionnel)	—	

> **Rappel : comment lit un pare-feu pfSense**
> Une règle s'applique au trafic *entrant* dans l'interface où elle est définie. La première règle qui correspond l'emporte. Ce qui n'est autorisé par aucune règle est bloqué. Les réponses aux connexions autorisées passent automatiquement (pare-feu à états).

5.2 Écrire les règles de l'interface USERS (exemple guidé)

SUR : FW-INT — Firewall > Rules > USERS > Add

1. **Règle 1** : Pass, TCP, source *USERS subnets*, destination alias `SRV_APP`, port `8080`, description « USERS vers application ».
2. **Règle 2** : navigation vers « Internet » = tout sauf les réseaux privés. Pass, TCP, source USERS subnets, destination alias `RFC1918` avec **Invert match**, ports HTTP (80) à HTTPS (443).
3. **Règle 3** : Block, any, any, any, **Log** coché. Apply Changes.

5.3 Écrire les règles des autres interfaces

À partir de votre matrice, complétez le jeu de règles de chaque interface (alias du TP3 ; « !RFC1918 » signifie « tout sauf les réseaux privés », soit « Internet »). Indices :

- **GUESTS** : une règle de passage vers Internet seulement, puis un blocage journalisé ;
- **MGMT** : l'administration vient d'une seule source (alias ADMIN_PC) vers les réseaux privés sur les ports de l'alias ADMIN_PORTS ; ajoutez un ICMP depuis ADMIN_PC pour le diagnostic ;
- **SERVERS** : rien n'est autorisé vers Internet ; seule la règle de journalisation (TP7) viendra plus tard ;
- **DMZ_LINK** : déjà fait au TP4.

À compléter — vos règles par interface (ordre, action, protocole, source, destination, port) :

USERS : 1. Pass TCP USERS net → SRV_APP:8080 ...

5.4 Créer le « faux Internet » pour tester la sortie

SUR : KALI — profil standard : KALI-EXT (203.0.113.100)

```
$ mkdir -p /tmp/fakeweb && echo 'Faux Internet' > /tmp/fakeweb/index.html
$ cd /tmp/fakeweb && sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80
```

Profil léger : conteneur WEB-EXT (CT 150) à la place. Create CT : hostname web-ext, 1 core, 128 MiB, disque 2 GiB, modèle Debian, d'abord sur vmbr9 (10.99.99.60/24, passerelle 10.99.99.1) pour `apt update && apt install -y python3`, puis carte sur **vmbr3** avec `203.0.113.100/24`, passerelle 203.0.113.1.

```
$ mkdir -p /srv/fakeweb && echo 'Faux Internet' > /srv/fakeweb/index.html
$ python3 -m http.server 80 --directory /srv/fakeweb &
```

5.5 Autoriser la sortie sur FW-EXT (règle + NAT sortant)

SUR : FW-EXT — https://172.16.50.1

1. Firewall > Aliases : créez `CLIENT_NETS` (Network(s)) = `192.168.10.0/24` et `192.168.40.0/24`.
2. Firewall > Rules > **DMZ** > Add : Pass, TCP, source `CLIENT_NETS`, destination any, ports HTTP (80) à HTTPS (443).
3. Firewall > NAT > Outbound : mode **Hybrid**, Save, puis Add : interface WAN, source `192.168.0.0/16`, destination any, translation *Interface Address*.

5.6 Premiers tests de la matrice

SUR : KALI — carte sur vmbr2, VLAN Tag 10

```
$ curl -I http://192.168.20.20:8080
HTTP/1.1 200 OK
$ curl -I http://203.0.113.100
HTTP/1.0 200 OK
$ curl -m 5 http://192.168.30.1
curl: (28) Connection timed out after 5001 milliseconds
$ nc -zv -w 3 192.168.20.30 3306
nc: connect to 192.168.20.30 port 3306 (tcp) timed out
```

Résultat attendu

Les deux premiers flux passent (application et faux Internet) ; le troisième (administration du pare-feu) et le quatrième (base de données) sont bloqués.

Si la sortie vers 203.0.113.100 échoue

Vérifiez dans l'ordre : règle USERS (80/443 vers !RFC1918), règle DMZ de FW-EXT (alias CLIENT_NETS), NAT sortant hybride 192.168.0.0/16, route statique de FW-EXT, WEB-EXT démarré. Si cela marche aussi vers 192.168.20.30 : règle trop large, vérifiez « Invert match ».

Question 5.1. Dans la matrice, pourquoi le flux n°4 (RP-DMZ vers la base de données) est-il refusé alors que RP-DMZ est de confiance ? Quelle architecture applicative évite d'avoir à l'autoriser ?

Votre réponse (enregistrée automatiquement)…

Question 5.2. Pourquoi n'autorise-t-on pas « USERS vers tous les ports du VLAN SERVERS » ? Donnez un exemple d'attaque que cela faciliterait.

Votre réponse (enregistrée automatiquement)…

Question 5.3. Expliquez la différence entre Block (abandon silencieux) et Reject (réponse de refus) pour un scanneur de ports. Lequel est préférable côté Internet ?

Votre réponse (enregistrée automatiquement)...

Question 5.4. Pourquoi l'ordre des règles est-il important ? Donnez un exemple où inverser deux règles change le résultat.

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] La matrice de flux est complétée et justifiée (14 lignes)
- [ ] Toutes les règles de FW-INT correspondent à la matrice ; les blocages sont journalisés
- [ ] Les tests de l'étape 5.6 donnent le résultat attendu
- [ ] Snapshots « tp5-ok » pris sur FW-EXT et FW-INT

TP6 — Audit avec Kali et fiche de recette

Durée 2 h · **Objectif** prouver que l'architecture se comporte comme la matrice de flux, en attaquant votre propre laboratoire, puis rédiger un mini-rapport d'audit · **Prérequis** TP5 · **À rendre** fiche de recette complétée, extraits de journaux, rapport (trois constats).

Cadre légal

Vous n'attaquez que les adresses 203.0.113.0/24, 172.16.50.0/24 et 192.168.x.0/24 de votre laboratoire. Relisez l'adresse de chaque commande avant de valider.

6.1 Lire un résultat nmap

État	Signification	Ce que cela indique
open	Le port répond : un service écoute	Flux autorisé et service actif

closed	La machine répond, mais aucun service n'écoute	Le pare-feu laisse passer, le service est arrêté
filtered	Aucune réponse : paquets abandonnés	Un pare-feu bloque (cas attendu pour un flux interdit)

Ajoutez `-Pn` quand le pare-feu bloque le ping : sans cette option nmap conclut à tort que l'hôte est éteint.

6.2 Test guidé T1 : scan depuis « Internet »

SUR : KALI — carte sur vmbr3 (rôle KALI-EXT)

Avant de lancer, écrivez dans la fiche de recette ce que vous attendez (6.7). Puis :

```
$ nmap -Pn -p- --min-rate 1000 203.0.113.1
Not shown: 65533 filtered tcp ports (no-response)
80/tcp open http    443/tcp open https
```

Sur 65 535 ports, seuls 80 et 443 répondent : c'est exactement la surface d'attaque voulue (les deux redirections NAT vers le reverse-proxy).

6.3 Test guidé T5 : scan depuis un poste du VLAN 10

```
$ nmap -Pn -p 22,80,8080,3306 192.168.20.20 192.168.20.30
192.168.20.20 → 8080 open ; 22, 80, 3306 filtered
192.168.20.30 → tout filtered
```

Comparez avec le TP1 : ici l'attaquant n'atteint plus que l'application, sur un seul port.

6.4 Test guidé : simuler la compromission du reverse-proxy

SUR : RP-DMZ — vous êtes « dans la peau » de l'attaquant qui a pris RP-DMZ

```
$ nc -zv -w 3 192.168.20.20 8080
Connection to 192.168.20.20 8080 port succeeded!
$ nc -zv -w 3 192.168.20.30 3306
timed out
$ nc -zv -w 3 192.168.10.100 22
timed out
```

Même avec RP-DMZ compromis, l'attaquant ne peut atteindre qu'un seul service interne.

6.5 Retrouver les blocages dans les journaux de FW-INT

Status > System Logs > Firewall : chaque tentative refusée est tracée (interface d'arrivée, source, destination, port). Exemple : `Block USERS 192.168.10.100:44012 → 192.168.20.20:22 TCP:S` ; `Block DMZ_LINK 172.16.50.10:39418 → 192.168.20.30:3306 TCP:S`.

Question 6.1. Recopiez trois lignes de journal correspondant à des tests refusés. Pour chacune, indiquez le test concerné (T5, T12…) et la règle qui a bloqué.

Votre réponse (enregistrée automatiquement)…

6.6 Tests autonomes

Réalisez les autres tests de la même façon (modifiez le bridge ou le VLAN Tag de KALI dans Proxmox selon la colonne « Depuis »). **Notez ce que vous attendez avant de lancer la commande.** Pour changer de VLAN : Hardware > Network Device > Edit, puis `sudo dhclient -r eth0 ; sudo dhclient eth0` (VLAN 10 et 40) ou 192.168.30.10/24 à la main (VLAN 30).

6.7 Fiche de recette

N°	Depuis	Commande	Attendu	Obtenu	OK / KO
T1	KALI-EXT	`nmap -Pn -p- --min-rate 1000 203.0.113.1`			—
T2	KALI-EXT	`nmap -Pn -sV -p 80,443 203.0.113.1`			—
T3	KALI-EXT	`curl -k -I https://203.0.113.1`			—
T4	KALI-EXT	`nmap -Pn -p 22,3306,8080 192.168.20.20 192.168.20.30`			—
T5	KALI (VLAN 10)	`nmap -Pn -p 22,80,8080,3306 192.168.20.20 192.168.20.30`			—
T6	KALI (VLAN 10)	`nc -zv -w 3 192.168.30.1 443`			—

T7	KALI (VLAN 10)	`curl -I http://192.168.20.20:8080`			—
T8	KALI (VLAN 10)	`curl -I http://203.0.113.100`			—
T9	KALI (VLAN 40)	`curl -m 5 http://192.168.20.20:8080`			—
T10	KALI (VLAN 40)	`curl -I http://203.0.113.100`			—
T11	RP-DMZ	`nc -zv -w 3 192.168.20.20 8080`			—
T12	RP-DMZ	`nc -zv -w 3 192.168.20.30 3306`			—
T13	RP-DMZ	`nc -zv -w 3 192.168.10.100 22`			—
T14	KALI (VLAN 30)	`nc -zv -w 3 192.168.20.30 22`			—
T15	KALI (VLAN 10)	`nc -zv -w 3 192.168.20.30 22`			—

Question 6.2. Relancez depuis le VLAN 10 l'analyse du TP1 (`nmap -Pn -p 22,80,3306,8080` sur les serveurs) : comparez le nombre de ports atteignables avec le réseau plat.

Votre réponse (enregistrée automatiquement)...

6.8 Rapport d'audit (3 constats)

Rédigez trois constats issus de vos tests : **une réussite de cloisonnement, une anomalie ou faiblesse restante, une amélioration possible**. Pour chacun : preuve (test, capture), risque, recommandation.

Constat 1 — réussite

Constat 2 — faiblesse restante

Constat 3 — amélioration possible

Validation de fin de TP

- [ ] La fiche de recette est entièrement remplie, les écarts sont expliqués
- [ ] Chaque test refusé est retrouvé dans les journaux (captures)
- [ ] Le rapport d'audit contient trois constats argumentés

TP7 — Durcissement et journalisation

Durée 2 h · **Objectif** ajouter la défense en profondeur côté serveurs (base, SSH, pare-feu local, services inutiles) et centraliser les journaux · **Prérequis** TP6, accès à la console Proxmox en cas de verrouillage SSH · **À rendre** captures, journaux centralisés, réponses.

7.1 Moindre privilège sur la base de données

SUR : SRV-BDD — console Proxmox

```
$ sudo mysql -e "DROP USER 'app'@'%'; CREATE USER 'app'@'192.168.20.20'
IDENTIFIED BY 'Un_Mot_De_Passe_Robuste_2026'; GRANT SELECT ON clients.* TO
'app'@'192.168.20.20'; FLUSH PRIVILEGES;"
$ sudo mysql -e "SELECT user, host FROM mysql.user WHERE user='app';"
app | 192.168.20.20
```

L'utilisateur ne peut plus se connecter que depuis SRV-APP et ne peut plus que lire.

7.2 Pare-feu local avec ufw

> **Attention au verrouillage**
> Autorisez SSH avant d'activer ufw. En cas d'erreur, la console Proxmox reste utilisable.

```
$ sudo ufw default deny incoming
$ sudo ufw default allow outgoing
$ sudo ufw allow from 192.168.30.10 to any port 22 proto tcp
$ sudo ufw allow from 192.168.20.20 to any port 3306 proto tcp
$ sudo ufw enable
$ sudo ufw status verbose
22/tcp ALLOW IN 192.168.30.10 · 3306/tcp ALLOW IN 192.168.20.20
```

7.3 SSH par clés, sans mot de passe

SUR : KALI — poste d'administration : VLAN Tag 30, 192.168.30.10/24

```
$ ssh-keygen -t ed25519
$ ssh-copy-id etudiant@192.168.20.30
$ ssh etudiant@192.168.20.30
connexion sans mot de passe
```

Puis sur SRV-BDD, éditez `/etc/ssh/sshd_config` :

```
PermitRootLogin no
PasswordAuthentication no
AllowUsers etudiant
MaxAuthTries 3
$ sudo sshd -t && sudo systemctl reload ssh
```

Toujours tester dans un second terminal avant de fermer la session. Depuis un poste sans la clé, la connexion doit être refusée : `Permission denied (publickey)`.

7.4 Réduire la surface d'attaque web

SUR : SRV-APP — console

```
$ sudo rm /etc/nginx/sites-enabled/default
$ sudo systemctl reload nginx
$ ss -tlnp
0.0.0.0:8080 (nginx) · 0.0.0.0:22 (sshd)   → le port 80 n'écoute plus
```

SUR : RP-DMZ — masquer la version et ajouter des en-têtes de sécurité

```
# dans /etc/nginx/nginx.conf, bloc http { ... } :
server_tokens off;
# dans /etc/nginx/conf.d/proxy.conf, bloc 'listen 443' :
add_header Strict-Transport-Security 'max-age=31536000' always;
add_header X-Content-Type-Options nosniff;
$ sudo nginx -t && sudo systemctl reload nginx
$ curl -k -I https://localhost | head -n 5
Server: nginx · Strict-Transport-Security: max-age=31536000 · X-Content-Type-
Options: nosniff
```

Mettez aussi les serveurs à jour (`sudo apt update && sudo apt full-upgrade -y`) pendant une courte fenêtre d'accès Internet via le bridge d'installation.

7.5 Centraliser les journaux dans SRV-LOG

SUR : SRV-LOG — recevoir les journaux

```
$ sudo nano /etc/rsyslog.d/10-recevoir.conf
module(load="imudp")
input(type="imudp" port="514")
module(load="imtcp")
input(type="imtcp" port="514")
$ sudo systemctl restart rsyslog
$ ss -ulnp | grep 514
0.0.0.0:514 rsyslogd
```

SUR : SRV-BDD — envoyer ses journaux

```
$ echo '*.* @@192.168.30.20:514' | sudo tee /etc/rsyslog.d/90-envoi.conf
$ sudo systemctl restart rsyslog
$ logger "test centralisation depuis srv-bdd"
```

Autorisez ce flux sur FW-INT, interface **SERVERS** : Pass, TCP, source `SRV_BDD`, destination `SRV_LOG`, port 514, Log coché, *avant* la règle de blocage. Puis faites envoyer les journaux du pare-feu : Status > System Logs > Settings > Enable Remote Logging, serveur `192.168.30.20:514`, Firewall Events.

```
# sur SRV-LOG
$ sudo grep -E "srv-bdd|filterlog" /var/log/syslog | tail -n 3
```

```
srv-bdd etudiant: test centralisation depuis srv-bdd
fw-int filterlog[27214]: ... vtnet1.10,match,block,in,4 ...
```

7.6 Sauvegarder

SUR : PROXMOX — console de pve1

```
$ vzdump 100 101 --storage local --mode snapshot
Backup job finished successfully
```

Sur chaque pare-feu : Diagnostics > Backup & Restore > *Download configuration as XML* ; conservez `config-fw-ext.xml` et `config-fw-int.xml`.

Question 7.1. Relancez T12 (RP-DMZ vers SRV-BDD). Le blocage est-il assuré une ou deux fois (pare-feu réseau, pare-feu local) ? Quel principe du cours cela illustre-t-il ?

Votre réponse (enregistrée automatiquement)...

Question 7.2. Pourquoi limiter l'utilisateur de la base à SELECT et à l'adresse de SRV-APP ? Quel scénario d'attaque cela empêche-t-il ?

Votre réponse (enregistrée automatiquement)...

Question 7.3. Provoquez un scan depuis KALI vers 192.168.20.20 : retrouvez l'événement dans SRV-LOG. Quel intérêt la centralisation des journaux a-t-elle en cas de compromission d'un serveur ?

Votre réponse (enregistrée automatiquement)...

Validation de fin de TP

- [ ] SRV-BDD : utilisateur restreint, ufw actif, SSH par clés uniquement
- [ ] SRV-APP n'écoute plus que sur 8080 (+ SSH). RP-DMZ masque sa version et envoie les en-têtes de sécurité
- [ ] Les événements de FW-INT et de SRV-BDD arrivent dans SRV-LOG

- [ ] Sauvegardes vzdump et configurations pfSense téléchargées

TP8 — Projet final et livrable

Durée 2 h + travail personnel · **Objectif** rassembler et justifier le travail : produire le dossier d'architecture sécurisée de l'entreprise fictive « Lab SA » · **À rendre** dossier PDF (schéma annoté, matrice, recette, rapport, justification) + sauvegardes.

> **Scénario**
> Lab SA compte 60 salariés. Elle publie un portail client, héberge une base de clients et accueille régulièrement des visiteurs. Le DSI vous demande un dossier démontrant que l'architecture protège le portail, la base et le poste d'un salarié, et que les flux sont maîtrisés.

8.1 Réaliser le schéma annoté avec draw.io

1. Ouvrez **app.diagrams.net** (ou draw.io Desktop), nouveau diagramme vierge.
2. Dessinez les zones comme des rectangles de couleur : Internet (gris), DMZ (orange), VLAN Utilisateurs (bleu), Serveurs (vert), Management (violet), Guests (gris clair).
3. Placez les équipements : FW-EXT, FW-INT, switch virtuel (trunk 802.1Q), RP-DMZ, SRV-APP, SRV-BDD, SRV-LOG, postes.
4. Tracez les flux par des flèches orientées du côté qui **initie** la connexion, avec protocole et port (« TCP 443 », « TCP 8080 »).
5. Ajoutez le plan d'adressage et les numéros de VLAN, une légende des couleurs, et numérotez les flux en renvoyant à la matrice.
6. Exportez : File > Export as > PDF (ou PNG).

8.2 Assembler les autres pièces du dossier

Pièce	D'où elle vient	À vérifier
Matrice de flux finale	Étape 5.1, mise à jour avec les règles réellement déployées	Une ligne par règle, justification présente
Fiche de recette	Étape 6.7 complétée	Attendu = obtenu ; écarts expliqués ; captures et journaux associés
Rapport d'audit	Étape 6.8	3 constats : preuve, risque, recommandation

Annexes techniques	Exports XML des pare-feu, résultat de vzdump	Fichiers datés et nommés

8.3 Rédiger la justification des choix (1 à 2 pages)

- Contexte et besoins : services à exposer, données sensibles ;
- Risques identifiés : intrusion externe, propagation latérale, rançongiciel, fuite de données ;
- Choix d'architecture : pourquoi un double pare-feu, pourquoi ces VLAN, pourquoi tel service en DMZ ; alternatives écartées ;
- Politique de filtrage : deny all, moindre privilège, ports retenus, journalisation ;
- Mesures complémentaires : durcissement, SSH par clés, supervision, sauvegardes ; ce qui reste à faire (limites).

Brouillon de la justification

8.4 Défis facultatifs

- Ajouter un WAF (ModSecurity) sur RP-DMZ et tester une injection SQL simple sur l'application de test ;
- Installer Suricata sur FW-EXT (IDS) et observer les alertes générées par un scan nmap ;
- Ajouter un accès VPN WireGuard en DMZ pour un administrateur distant, avec accès limité au VLAN 30 ;
- Mettre en place une seconde DMZ pour un relais de messagerie et rédiger les règles associées ;
- Reproduire l'architecture sur du matériel réel avec un switch Cisco (annexe C).

Question 8.1. En une dizaine de lignes, argumentez pour le DSI : pourquoi cette architecture est-elle plus sûre qu'un réseau plat ? Quelles sont ses limites ?

Votre réponse (enregistrée automatiquement)...

Annexes

A — Aide-mémoire des commandes

Besoin	Commande
Proxmox (sur l'hôte)	
Lister les VM	`qm list`
Démarrer / arrêter une VM	`qm start 110` ; `qm shutdown 110`
Cloner un gabarit	`qm clone 900 120 --name srv-app --full`
Changer le VLAN d'une carte	`qm set 130 --net0 virtio,bridge=vmbr2,tag=40`
Snapshot / retour arrière	`qm snapshot 130 tp3-ok` ; `qm rollback 130 tp3-ok`
Sauvegarder	`vzdump 100 101 --storage local --mode snapshot`
Bridges et VLAN	`ip -br link show type bridge` ; `bridge vlan show`
Linux (serveurs et postes)	
Adresses, routes	`ip -br a` ; `ip route`
Ports en écoute	`ss -tlnp`
Tester un port TCP	`nc -zv -w 3 192.168.20.20 8080`
Tester une page web	`curl -I http://hôte:port` ; `curl -k -I https://hôte`
Chemin réseau	`traceroute 203.0.113.100`
Capturer le trafic	`sudo tcpdump -ni ens18 host 192.168.20.20 and port 8080`

Pare-feu local	`sudo ufw status verbose`
Journaux	`sudo journalctl -u nginx -n 50` ; `tail -f /var/log/nginx/access.log`
nmap (Kali)	
Découvrir les hôtes	`nmap -sn 192.168.100.0/24`
Scanner sans ping préalable	`nmap -Pn -p 22,80,443 cible`
Tous les ports TCP	`nmap -Pn -p- --min-rate 1000 cible`
Versions de services	`nmap -Pn -sV -p 80,443 cible`
Enregistrer le résultat	`nmap -Pn -oN resultat.txt cible`

B — Dépannage

Symptôme	Cause probable	Vérification et solution
La VM n'a pas d'adresse DHCP	Mauvais bridge ou VLAN Tag ; DHCP non activé	Proxmox : bridge et tag ; pfSense : Services > DHCP Server de la bonne interface
Tout est bloqué, même le ping de la passerelle	Aucune règle sur l'interface (deny all)	Normal tant qu'aucune règle n'existe ; ajoutez une règle ICMP vers « This Firewall »
Les paquets VLAN n'arrivent pas au pare-feu	Bridge non « VLAN aware » ; carte du pare-feu avec un tag	vmbr2 : VLAN aware coché ; carte trunk de FW-INT sans tag
Connexion TCP lente ou qui se coupe	Offload de checksum avec VirtIO	System > Advanced > Networking : désactiver le hardware checksum offload
Interface web du pare-feu inaccessible	Mauvaise adresse ou règle supprimée	Console : option 8, `pfctl -d` ; rétablir avec `pfctl -e`
RP-DMZ ne joint pas SRV-APP	Route 192.168.0.0/16 manquante ; règle DMZ_LINK absente	`ip route` sur RP-DMZ ; journal de FW-INT filtré sur 172.16.50.10

Publication web impossible depuis KALI-EXT	Règle WAN absente ; blocage bogon / RFC1918 encore coché	Firewall > Rules > WAN ; interface WAN : décocher les deux blocages
Réponses qui repartent par FW-EXT	reply-to actif sur DMZ_LINK	FW-INT : System > Advanced > Firewall & NAT : « Disable reply-to on WAN rules »
nmap annonce « host seems down »	Le pare-feu bloque le ping	Ajouter `-Pn`
Les clients internes ne joignent pas « Internet »	NAT sortant absent sur FW-EXT ; route retour manquante	NAT > Outbound hybride pour 192.168.0.0/16 ; route statique sur FW-EXT

C — Équivalent sur un switch Cisco

```
vlan 10
 name USERS
vlan 20
 name SERVEURS
vlan 30
 name MANAGEMENT
vlan 40
 name GUESTS
!
interface fastEthernet 0/1
 switchport mode access
 switchport access vlan 10
 spanning-tree bpduguard enable
 switchport port-security
!
interface gigabitEthernet 0/1
 description TRUNK vers FW-INT
 switchport mode trunk
 switchport trunk allowed vlan 10,20,30,40
 switchport trunk native vlan 99
!
interface range fastEthernet 0/10 - 24
 switchport access vlan 99
 shutdown
```

Correspondance : le bridge « VLAN aware » de Proxmox joue le rôle du switch ; le VLAN Tag d'une carte VM correspond à un port *access* ; une carte sans tag reliée à FW-INT correspond à un port *trunk*.

D — Grille d'évaluation

Compétence évaluée	Indicateurs	Points
Plateforme et VLAN (TP0, TP3)	Bridges corrects, VLAN fonctionnels, DHCP par VLAN, gabarits exploités	3
Pare-feu et zones (TP2)	Zones nommées, deny all, routage entre pare-feu	3
DMZ et reverse-proxy (TP4)	Publication HTTPS, NAT, flux DMZ limité au strict nécessaire	3
Matrice et règles (TP5)	Matrice cohérente et justifiée, règles conformes au moindre privilège	4
Audit et recette (TP6)	Tests pertinents, écarts expliqués, preuves dans les journaux	3
Durcissement et journaux (TP7)	SSH par clés, ufw, utilisateur restreint, journaux centralisés	2
Dossier final (TP8)	Schéma annoté lisible, justification argumentée, rigueur	2
Total		**20**

Les questions, les snapshots et les captures servent de support à l'oral : l'enseignant peut demander de reproduire un test (par exemple T9 ou T12) en direct.

© 2026 **Twagirumukiza** — Support pédagogique BTS SIO 2 · Cybersécurité

Suivre Twagirumukiza sur LinkedIn ↗